

ENCUESTA INTEGRAL DE CIBERSEGURIDAD BASADA EN OWASP SAMM v2

Modelo Detallado con Módulos y Escalas de Madurez

Versión: 2.0 | **Fecha:** Enero 2026 | **Ámbito:** Nacional (España) e Internacional

Metodología: Multi-stakeholder | **Duración estimada:** 45-60 minutos | **Público:** Organizaciones de todas las categorías

PROPÓSITO Y CONTEXTO

Esta encuesta evalúa la madurez de ciberseguridad en el desarrollo, operación y gestión de software en su organización, alineada con el **OWASP Software Assurance Maturity Model (SAMM) v2**, complementada con indicadores de **análisis de vulnerabilidades, pruebas de penetración, gestión de información y eventos de seguridad (SIEM)**, y **capacitación de empleados en seguridad**.

La encuesta reconoce que diferentes roles (Gobernanza, Desarrollo, Arquitectura, Operaciones, Verificación) poseen perspectivas distintas sobre madurez. **Cada respuesta es igualmente valiosa**—no es cuestión de "quién está bien" sino de construir una visión compartida donde la fricción entre perspectivas se convierte en **oportunidad de mejora**.

INSTRUCCIONES GENERALES

Para Respondentes

1. Lea cada pregunta cuidadosamente. Algunas preguntas exploran la existencia de prácticas; otras, la sofisticación.
2. Responda desde su experiencia real. No responda cómo desearía que fuera su organización, sino cómo realmente es.
3. Si no sabe: Seleccione "No tengo suficiente visibilidad" (una opción válida que ayuda a identificar brechas de comunicación).
4. Tiempo total: 45-60 minutos. Puede tomarse descansos.
5. Confidencialidad: Sus respuestas se rigen por confidencialidad y se reportarán solo agregadas a nivel organizacional, nunca individual.

Escala de Respuesta

La encuesta utiliza una **escala ordinal de 5 puntos** derivada de SAMM v2 y modelos de madurez estándar:

Código	Nivel	Interpretación
0	No implementado	La práctica/actividad no existe o es completamente ad-hoc.
1	Inicial	La práctica existe de manera informal e inconsistente; esfuerzo reactivo.
2	Definido	La práctica está documentada y se implementa consistentemente; existe proceso.
3	Medido	La práctica incluye métricas; resultados se monitorean y revisan regularmente.
4	Optimizado	La práctica está automatizada; mejora continua es sistemática.

Notas sobre la escala:

- **Nivel 0-1:** Ad-hoc, reactivo, informal
- **Nivel 2-3:** Estructurado, proactivo, con visibilidad
- **Nivel 4:** Optimizado, automatizado, ágil

Para **ciertos módulos (SIEM, Capacitación)**, se incluyen preguntas binarias o específicas de implementación complementarias.

MÓDULO 1: DATOS DEMOGRÁFICOS Y CONTEXTO ORGANIZACIONAL

Tiempo estimado: 5 minutos

Esta sección captura contexto organizacional que facilita análisis comparativo y segmentación posterior.

1.1 Información Organizacional

[M1.1.1] ¿Cuál es el sector económico principal de su organización?

- Servicios Financieros (Banca, Seguros, Fondos)
- Tecnología e Informática
- Telecomunicaciones
- Sanidad (Hospitales, Farma, Salud Pública)
- Energía (Electricidad, Gas, Oil)
- Transporte (Aéreo, Ferroviario, Marítimo, Carretero)
- Administración Pública / Sector Público
- Manufactura / Industria
- Retail / Comercio
- Educación / Investigación

- Medios / Comunicación
- Otra (especifique): ____

[M1.1.2] ¿Cuántos empleados tiene su organización?

- Micro (1-9)
- Pequeña (10-49)
- Mediana (50-249)
- Grande (250-999)
- Muy Grande (≥ 1000)

[M1.1.3] ¿En cuántas jurisdicciones opera su organización?

- Solo España
- España + Europa
- España + Global
- Otro: ____

[M1.1.4] Dentro de su organización, ¿cuál es su rol principal? (Seleccione uno)

- Gobernanza / Estrategia (CISO, Director de Seguridad, Chief Risk Officer)
- Desarrollo / Ingeniería (Developer, Tech Lead, Software Architect)
- Arquitectura (Enterprise Architect, Solution Architect, Security Architect)
- Operaciones / Infraestructura (DevOps, Infrastructure, System Admin, Operations Manager)
- Verificación / Testing (QA, Security Tester, Penetration Tester, Security Auditor)
- Cumplimiento / Legal (Compliance Officer, Data Protection Officer, Legal Counsel)
- Otro: ____

[M1.1.5] ¿Desde cuántos años trabaja en el ámbito de ciberseguridad o seguridad de software?

- < 2 años
- 2-5 años
- 5-10 años
- 10-15 años
- > 15 años

MÓDULO 2: GOBERNANZA (GOVERNANCE)

Tiempo estimado: 8-10 minutos

Este módulo evalúa cómo su organización define, comunica y mide la estrategia de seguridad de software.

2.1 Práctica: Estrategia y Métricas

[G2.1.1] Estrategia de Seguridad de Software

¿Existe un documento formal de estrategia o roadmap de seguridad de aplicaciones plurianual?

- 0 = No existe | No se ha definido una estrategia
- 1 = Existe informal | Se comunica verbalmente; no documentado o ad-hoc
- 2 = Existe y es documentada | Plan por escrito; revisión anual o menos
- 3 = Documentada con métricas | Plan documentado; revisión trimestral; métricas definidas
- 4 = Optimizada y adaptativa | Plan dinámico; revisión continua; ajustes basados en datos

[G2.1.2] Alineación con Objetivos de Negocio

¿Cómo se alinea la estrategia de seguridad con objetivos empresariales?

- 0 = Sin alineación | Seguridad es responsabilidad aislada de IT
- 1 = Comunicación informal | Se comunica el por qué; sin mapeo explícito
- 2 = Alineación explícita | Objetivos de seguridad mapeados a objetivos de negocio
- 3 = Alineación integrada | Métricas compartidas; revisión conjunta Negocio-Seguridad
- 4 = Integración profunda | Seguridad es criterio de decisión en todas las iniciativas

[G2.1.3] Definición de Métricas y KPIs

¿Cuáles de las siguientes métricas de seguridad de aplicaciones *están definidas formalmente* en su organización? (*Marque todos los que apliquen*)

- ☐ Cobertura de threat modeling (% aplicaciones con threat model)
- ☐ Defects discovery rate (vulnerabilidades encontradas en testing / históricas)
- ☐ Patch compliance (% sistemas parchados en SLA)
- ☐ MTTD - Mean Time to Detect incidentes
- ☐ MTTR - Mean Time to Remediate incidentes
- ☐ Security test coverage (% requisitos de seguridad con casos de prueba)
- ☐ Incident response capability (# ejercicios anuales; % participación)
- ☐ Training completion rate (% empleados entrenados; horas per-capita)
- ☐ Vulnerability remediation time (media de días de vulnerabilidad abierta)
- ☐ False positive ratio en detección (señal/ruido)
- Ninguno o muy pocos
- No tengo suficiente visibilidad

[G2.1.4] Comunicación de Métricas

¿Con qué frecuencia se comunican métricas de seguridad de software a liderazgo ejecutivo (C-level)?

- 0 = Nunca o ad-hoc (cuando hay incidente)
- 1 = Anual o menos frecuente
- 2 = Trimestral
- 3 = Mensual o bi-semanal
- 4 = Semanal o continuo (dashboard disponible)

2.2 Práctica: Cumplimiento y Políticas

[G2.2.1] Políticas de Seguridad de Software

¿Existen políticas formales documentadas que cubre los siguientes temas? (*Marque todos*)

- ☐ Requisitos de seguridad en especificación de software
- ☐ Estándares de codificación segura
- ☐ Gestión de dependencias / componentes de terceros
- ☐ Validación y testing de seguridad obligatorio
- ☐ Clasificación y gestión de datos sensibles
- ☐ Incidentes de seguridad: reporte y escalación
- ☐ Acceso a código / repositorios (control de acceso)
- ☐ Gestión de secretos (credenciales, tokens)
- ☐ Cumplimiento normativo (GDPR, NIS2, CRA, ISO 27001, etc.)
- ☐ Continuidad de negocio y disaster recovery
- Menos de 3 políticas | 3-5 políticas | 6-8 políticas | 9+ políticas

[G2.2.2] Nivel de Cumplimiento de Políticas

¿Qué porcentaje de aplicaciones/equipos en su organización **implementan activamente** las políticas de seguridad de software?

- 0-25% (Ad-hoc, mayormente ignoradas)
- 26-50% (Implementación inconsistente)
- 51-75% (Mayoría cumple; excepciones documentadas)
- 76-90% (Cumplimiento alto; auditoría regular)
- 91-100% (Cumplimiento completo; automatizado en procesos)

[G2.2.3] Auditoría de Cumplimiento

¿Con qué frecuencia se auditan las políticas de seguridad de software para verificar su cumplimiento?

- 0 = Nunca audita
- 1 = Ad-hoc (cuando se identifica problema)
- 2 = Anual
- 3 = Trimestral o semestral
- 4 = Continuo (automatizado, alertas en tiempo real)

2.3 Práctica: Educación y Capacitación

[G2.3.1] Programa de Capacitación

¿Existe un programa formal de capacitación en seguridad de software?

- 0 = No existe
- 1 = Ad-hoc (sesiones ocasionales)
- 2 = Programa básico documentado (anual para nuevos empleados)
- 3 = Programa estructurado (anual + reciclaje por roles)
- 4 = Programa adaptativo (personalizado por rol; continuo)

[G2.3.2] Cobertura de Capacitación

¿Qué porcentaje de desarrolladores y personal técnico **recibe capacitación formal** en seguridad de software anualmente?

- 0-25%
- 26-50%
- 51-75%
- 76-90%
- 91-100%

[G2.3.3] Temas de Capacitación

¿Cuáles de los siguientes temas se cubren en la capacitación de seguridad? (*Marque todos*)

- ☐ OWASP Top 10 y vulnerabilidades comunes
- ☐ Threat modeling / análisis de amenazas
- ☐ Codificación segura (secure coding)
- ☐ Gestión de dependencias / supply chain security
- ☐ Testing de seguridad (SAST, DAST, manual penetration testing)
- ☐ Gestión de secretos / credenciales
- ☐ Incident response y comunicación de crisis
- ☐ Compliance (GDPR, NIS2, CRA, ISO 27001)
- ☐ Seguridad en DevOps/CI-CD pipelines
- ☐ Entrenamiento en phishing / awareness general

[G2.3.4] Eficacia de la Capacitación

¿Cómo mide su organización la eficacia de la capacitación en seguridad?

- 0 = No mide | Solo cuenta asistencia
- 1 = Quiz post-capacitación
- 2 = Quiz + evaluación de conocimiento
- 3 = Quiz + simulations (ej: phishing simulado) + evaluación de cambio de comportamiento
- 4 = Medición continua (cambios en comportamiento observados; auditoría de código post-training)

MÓDULO 3: DISEÑO (DESIGN)

Tiempo estimado: 8-10 minutos

Este módulo evalúa cómo se incorpora seguridad en la fase de diseño arquitectónico y de requisitos.

3.1 Práctica: Evaluación de Amenazas (Threat Assessment)

[D3.1.1] Threat Modeling

¿Qué porcentaje de **aplicaciones críticas o nuevas** tienen un threat model documentado?

- 0 = 0% (Ninguno)
- 1 = 1-25% (Algunos aplicados ad-hoc)
- 2 = 26-50% (Mayoría de nuevos proyectos)
- 3 = 51-75% (Threat modeling estándar en nuevos; actualización periódica)
- 4 = 76-100% (100% de críticos; threat model vivo en cada sprint)

[D3.1.2] Metodología de Threat Modeling

¿Cuál de las siguientes metodologías se utiliza en su organización? (*Seleccione todas*)

- ☐ STRIDE (Microsoft)
- ☐ PASTA (Process for Attack Simulation and Threat Analysis)
- ☐ OCTAVE (Operationally Critical Threat, Asset, and Vulnerability Evaluation)
- ☐ CAPEC (Common Attack Pattern Enumeration and Classification)
- ☐ LINDDUN (Privacy-focused)
- ☐ Metodología personalizada / interna
- ☐ Metodología ad-hoc / no estructurada
- ☐ No tenemos metodología formal

[D3.1.3] Cobertura de Threat Modeling

Cuando se realiza threat modeling, ¿qué aspectos se **analizan sistemáticamente**? (*Marque todos*)

- ☐ Flujos de datos (data flows)
- ☐ Puntos de entrada (entry points)
- ☐ Límites de confianza (trust boundaries)
- ☐ Amenazas por categoría (Spoofing, Tampering, Repudiation, etc.)
- ☐ Mitigaciones existentes o propuestas
- ☐ Supuestos de seguridad
- ☐ Dependencias de terceros / supply chain

3.2 Práctica: Requisitos de Seguridad

[D3.2.1] Derivación de Requisitos

¿Cómo se derivan los requisitos de seguridad en su organización?

- 0 = Ad-hoc o no se derivan; solo funcionales
- 1 = Basados en checklist genérico (OWASP Top 10)
- 2 = Derivados de threat model + estándares internacionales
- 3 = Derivados de threat model + riesgos específicos de negocio + estándares
- 4 = Automatizado: threat model – requisitos; trazabilidad código-requisito

[D3.2.2] Trazabilidad de Requisitos

¿Existe trazabilidad entre requisitos de seguridad y código implementado?

- 0 = No; requisitos viven en documento separado
- 1 = Manual; documentación pero sin automatización
- 2 = Parcialmente automatizada; herramientas para rastrear (ej: Jira)
- 3 = Automatizada; ALM (Application Lifecycle Management) integrado
- 4 = Totalmente integrada; validación continua requisito-código

[D3.2.3] Validación de Requisitos

¿Con qué frecuencia se **revisan y actualizan** los requisitos de seguridad?

- 0 = Nunca; establecidos una sola vez
- 1 = Ad-hoc, cuando se identifica vulnerability
- 2 = Anual o por mayor release
- 3 = Trimestral o cada release menor
- 4 = Continuo (cada sprint o cambio significativo)

3.3 Práctica: Arquitectura Segura

[D3.3.1] Arquitectura de Referencia

¿Existe una arquitectura de referencia o patrones de seguridad documentados?

- 0 = No existe
- 1 = Existe informal, disperso en wikis/blogs
- 2 = Documentado en un lugar; acceso limitado
- 3 = Documentado; publicado; algunas actualizaciones
- 4 = Vivo; versioned; actualizado con cada threat landscape change; herramientas de validación

[D3.3.2] Alineación Arquitectónica

¿Qué porcentaje de **nuevas aplicaciones** se alinean con la arquitectura de referencia/patrones de seguridad?

- 0-25%
- 26-50%
- 51-75%
- 76-90%
- 91-100%

[D3.3.3] Decisiones de Seguridad

¿Cómo se documentan las decisiones arquitectónicas de seguridad (Architecture Decision Records)?

- 0 = No se documentan
- 1 = Documentadas informalmente (emails, notas)
- 2 = Documentadas en Wiki / repositorio; sin estructura
- 3 = Documentadas en ADRs formales; histórico de decisiones
- 4 = ADRs automatizados; vinculados a análisis de riesgo y threat models

MÓDULO 4: IMPLEMENTACIÓN (IMPLEMENTATION)

Tiempo estimado: 10-12 minutos

Este módulo evalúa cómo se construye, integra y despliega software de forma segura.

4.1 Práctica: Construcción Segura (Secure Build)

[I4.1.1] Automatización de Build

¿Qué porcentaje de aplicaciones tiene un proceso de build **totalmente automatizado**?

- 0-25%
- 26-50%
- 51-75%
- 76-90%
- 91-100%

[I4.1.2] Gates de Seguridad en Build

¿Cuáles de las siguientes comprobaciones de seguridad **detienen automáticamente** un build si falla?
(Marque todos)

- ☐ SAST (Static Application Security Testing) falla
- ☐ SCA (Software Composition Analysis) identifica vulnerabilidad conocida crítica
- ☐ Firma de código falla o no se puede verificar
- ☐ Imagen de contenedor falla escaneo de vulnerabilidades
- ☐ Secrets detectados en código (credential scanning)
- ☐ Tests unitarios de seguridad fallan
- Ninguno (fallos se permiten continuar)
- No tenemos gates de seguridad

[I4.1.3] Análisis Estático de Seguridad (SAST)

¿Cuál es el estado de SAST en su organización?

- 0 = No existe
- 1 = Iniciativa piloto; no estándar
- 2 = SAST integrado en algunos proyectos / equipos
- 3 = SAST estándar en todos los builds; resultados revisados manualmente
- 4 = SAST automatizado; findings triaged automáticamente; remediación tracked

[I4.1.4] Componentes y Dependencias

¿Cómo se gestiona la seguridad de componentes/dependencias de terceros?

- 0 = Ad-hoc; sin control formal
- 1 = Manual; lista de componentes; sin validación de vulnerabilidades
- 2 = SCA básico; identifica vulnerabilidades conocidas
- 3 = SCA avanzado; incluye reachability analysis; license compliance
- 4 = SCA + SBOM; decisiones automatizadas; remediación tracked

[I4.1.5] Firma de Código

¿Qué porcentaje de código/builds incluye verificación de firma (code signing)?

- 0% (No existe)
- 1-25%
- 26-50%
- 51-75%
- 76-100% (Requerido en todos)

4.2 Práctica: Despliegue Seguro (Secure Deployment)

[I4.2.1] Verificación de Integridad en Despliegue

¿Se verifica la integridad de los artefactos durante el despliegue?

- 0 = No
- 1 = Manual, inconsistente
- 2 = Automatizado; algunos tipos de artefactos
- 3 = Automatizado; todos los tipos; checksum/firma validados
- 4 = Automatizado; incluye provenance tracking; atestación de build

[I4.2.2] Gestión de Secretos

¿Cómo se manejan secretos (credenciales, tokens, keys) durante despliegue?

- 0 = Hardcoded en código o código | En ficheros no encriptados
- 1 = Algunos secretos en external config; no consistente
- 2 = Secretos en vault externo; acceso restringido
- 3 = Vault centralizado; auditoría de acceso; rotación periódica
- 4 = Vault automatizado; rotación automática; zero-knowledge proof of access

[I4.2.3] Configuración Segura de Despliegue

¿Se verifica que la configuración de despliegue cumple con baseline de seguridad?

- 0 = No se verifica
- 1 = Ad-hoc; revisión manual
- 2 = Checklist de configuración; manual
- 3 = Automated scanning; comparación contra baseline; alertas de desvío
- 4 = Inmutable infrastructure; desvíos previenen despliegue; compliance continua

[I4.2.4] Entornos de Despliegue

¿Cuántos entornos separados existen en su pipeline (Development, Staging, Production)?

- 1 (Todo en Production o casi)
- 2 (Dev + Prod)
- 3 (Dev, Staging, Prod)
- 4+ (Dev, QA, Staging, UAT, Production)

[I4.2.5] Seguridad de Contenedores

(Si aplica: si usas contenedores/Kubernetes)

¿Qué tan maduros son los controles de seguridad de contenedores?

- N/A (No usamos contenedores)
- 0 = No existe
- 1 = Scanning básico; imágenes no patchadas
- 2 = Escaneo de vulnerabilidades; algunas políticas de runtime
- 3 = Escaneo + admission control + network policies
- 4 = Immutable images; scanning continuo; compliance enforced

4.3 Práctica: Gestión de Defectos (Defect Management)

[I4.3.1] Rastreo de Defectos de Seguridad

¿Tiene un sistema formal para rastrear vulnerabilidades/defectos de seguridad?

- 0 = No
- 1 = Ad-hoc; en Jira / issue tracker genérico sin separación
- 2 = Sistema dedicado o etiquetado; con categorización básica
- 3 = Sistema dedicado; categorización por severidad (CVSS/EPSS); SLA por severidad
- 4 = Automatizado; threat intelligence integrado; predicción de explotabilidad

[I4.3.2] SLA por Severidad

¿Existen SLAs definidos para remediación de vulnerabilidades? (*Marque los que existan*)

- ☐ Crítico: remediación en < 24h
- ☐ Alto: remediación en < 7 días
- ☐ Medio: remediación en < 30 días
- ☐ Bajo: remediación en < 90 días
- No tenemos SLAs formales

[I4.3.3] Ratio de Cierre Pre-Producción

¿Qué porcentaje de vulnerabilidades se **cierran ANTES de que la aplicación llegue a Producción**?

- 0-25% (La mayoría llega a Producción)
- 26-50%
- 51-75%
- 76-90%
- 91-100% (Gatekeeper efectivo)

[I4.3.4] Priorización de Defectos

¿Cómo se priorizan los defectos de seguridad?

- 0 = Ad-hoc; por quien lo reportó
- 1 = CVSS score solamente
- 2 = CVSS + contexto (asset criticality, data sensitivity)
- 3 = CVSS + EPSS + contexto + exploitability evidence
- 4 = Automático: CVSS + EPSS + contexto + threat intel + impact modeling

MÓDULO 5: VERIFICACIÓN (VERIFICATION)

Tiempo estimado: 8-10 minutos

Este módulo evalúa cómo se valida que la seguridad se implementó correctamente.

5.1 Práctica: Evaluación de Arquitectura

[V5.1.1] Revisión de Arquitectura de Seguridad

¿Qué porcentaje de **aplicaciones críticas** reciben una revisión arquitectónica de seguridad **al menos anualmente**?

- 0-25%
- 26-50%
- 51-75%
- 76-90%
- 91-100%

[V5.1.2] Metodología de Revisión

¿Cuál es el enfoque de revisión arquitectónica?

- 0 = No existe
- 1 = Ad-hoc; checklist genérico
- 2 = Estructurado; basado en threat model + OWASP Top 10
- 3 = Formal; contra arquitectura de referencia + análisis de riesgos
- 4 = Continuo; automated scanning + manual review; validación en cada cambio

[V5.1.3] Hallazgos y Remediación

¿Se rastrea y cierra explícitamente los hallazgos de revisiones arquitectónicas?

- 0 = No se documenta
- 1 = Se documenta pero no se rastrea cierre
- 2 = Se rastrea; cierre manual; sin SLA
- 3 = Se rastrea; SLA por severidad; revisión de cierre
- 4 = Automatizado; vinculado a defect management system; compliance tracked

5.2 Práctica: Testing Impulsado por Requisitos

[V5.2.1] Cobertura de Requisitos de Seguridad

¿Qué porcentaje de **requisitos de seguridad** tienen casos de prueba documentados?

- 0-25%
- 26-50%
- 51-75%
- 76-90%
- 91-100%

[V5.2.2] DAST (Análisis Dinámico)

¿Cuál es el estado de DAST (dynamic scanning) en su organización?

- 0 = No existe
- 1 = Piloto; no consistente
- 2 = DAST integrado en algunos proyectos
- 3 = DAST estándar en todos los releases; resultados revisados
- 4 = DAST continuo; automatizado; correlacionado con SAST

[V5.2.3] Testing de Abuso (Abuse Case Testing)

¿Se conducen pruebas explícitas de "abuse cases" (escenarios de ataque)?

- 0 = No
- 1 = Ad-hoc; solo en incidentes
- 2 = En algunos proyectos; no estándar
- 3 = Estándar en nuevas aplicaciones; documentado
- 4 = Continuo; integrado en cada sprint; threat-driven

[V5.2.4] Penetration Testing

¿Con qué frecuencia se realizan penetration tests (internos o externos)?

- 0 = Nunca
- 1 = Ocasional (cada 2-3 años)
- 2 = Anual
- 3 = Semestral o por major release
- 4 = Trimestral o continuo (red team interno)

[V5.2.5] Simulación de Amenazas

¿Se conducen ejercicios de simulación de amenazas (tabletop exercises, attack simulations)?

- 0 = No
- 1 = Ad-hoc
- 2 = Anual
- 3 = Semestral
- 4 = Trimestral o más frecuente

MÓDULO 6: OPERACIONES (OPERATIONS)

Tiempo estimado: 10-12 minutos

Este módulo evalúa cómo se mantiene la seguridad en producción.

6.1 Práctica: Gestión de Incidentes

[06.1.1] Respuesta a Incidentes

¿Existe un plan formal y documentado de respuesta a incidentes de seguridad?

- 0 = No existe
- 1 = Existe informal; roles no claros
- 2 = Plan documentado; roles y responsabilidades definidos
- 3 = Plan documentado; entrenamiento anual; métricas de respuesta
- 4 = Plan vivo; entrenamiento trimestral; ejercicios regulares; métricas continuas

[06.1.2] MTTD (Mean Time to Detect)

¿Cuál es el tiempo **promedio** para detectar un incidente de seguridad desde que ocurre?

•

7 días (Ad-hoc o muy lento)

- 3-7 días
- 1-3 días
- < 1 día (< 24 horas)
- < 1 hora (Monitoreo en tiempo real)
- No tenemos métricas

7 días (Ad-hoc o muy lento)

[06.1.3] MTTR (Mean Time to Remediate)

¿Cuál es el tiempo **promedio** para resolver un incidente de severidad **Alta**?

•

30 días

- 15-30 días
- 7-15 días
- 1-7 días
- < 24 horas
- No tenemos métricas

30 días

[06.1.4] Escalación de Incidentes

¿Cómo se escalan los incidentes según severidad?

- 0 = Ad-hoc
- 1 = Escalación informal; sin procedimiento
- 2 = Procedimiento documentado; escalación por severidad
- 3 = Automatizado; alertas a stakeholders; tracking de escalación
- 4 = Automático; notificación en tiempo real; comunicación a reguladores si aplica

[06.1.5] Post-Mortem de Incidentes

¿Se conducen análisis post-mortem ("post-incident reviews") de incidentes de seguridad?

- 0 = No
- 1 = Ad-hoc; solo para incidentes mayores
- 2 = Para todos los incidentes; no estructurado
- 3 = Estructurado; lessons learned documentadas; acciones de mejora asignadas
- 4 = Sistematizado; resultados publicados; feedback integrado en desarrollo

6.2 Práctica: Gestión de Entorno

[06.2.1] Hardening de Sistemas

¿Existe un baseline de configuración ("hardened baseline") para sistemas productivos?

- 0 = No existe
- 1 = Existe pero no se verifica
- 2 = Existe; verificación manual anual
- 3 = Existe; verificación automatizada; desvíos reportados
- 4 = Hardening automatizado; inmutable; verificación continua; compliance enforced

[06.2.2] Gestión de Parches

¿Cuál es el **máximo plazo** para parchear un sistema contra una vulnerabilidad **Crítica** conocida?

-

60 días (Ad-hoc)

- 30-60 días
- 7-30 días
- 1-7 días
- < 24 horas (Hot patch capability)
- No tenemos SLA

60 días (Ad-hoc)

[06.2.3] Distribución de Patches

¿Cuál es la cobertura de sistemas que **reciben patches dentro del SLA**?

- 0-25%
- 26-50%
- 51-75%
- 76-90%
- 91-100%

[06.2.4] Inventario de Activos

¿Se mantiene un inventario actualizado de todos los sistemas en producción?

- 0 = No existe
- 1 = Existe pero desactualizado (> 6 meses)
- 2 = Actualizado manualmente; 3-6 meses atraso
- 3 = Actualizado automáticamente; < 1 mes atraso
- 4 = Real-time; descubrimiento continuo; integrado con otras herramientas

6.3 Práctica: Protección de Datos

[06.3.1] Clasificación de Datos

¿Cuál es la cobertura de **clasificación de datos** en su organización?

- 0 = No existe
- 1 = Clasificación ad-hoc; inconsistente
- 2 = Clasificación definida; aplicada a datos críticos solamente
- 3 = Clasificación estándar; aplicada a mayoría de datos; revisión periódica
- 4 = Clasificación automatizada; aplicada a todos los datos; revisión continua

[06.3.2] Niveles de Clasificación

¿Cuáles de los siguientes niveles de clasificación existen en su organización? (*Marque todos*)

- ☐ Público
- ☐ Interno
- ☐ Confidencial
- ☐ Secreto / Altamente Sensible
- ☐ PII (Personally Identifiable Information)
- ☐ PHI (Protected Health Information)
- ☐ PCI (Payment Card Information)
- Otro: _____
- No tenemos clasificación formal

[06.3.3] Controles por Nivel de Sensibilidad

¿Existen controles de acceso específicos según nivel de sensibilidad de datos?

- 0 = No; acceso igual para todos
- 1 = Algunos controles; no consistente
- 2 = Controles definidos; parcialmente implementados
- 3 = Controles completamente implementados; revisión anual
- 4 = Controles automáticos; revisión continua; compliance tracked

[06.3.4] Encriptación de Datos

¿Qué controles de encriptación existen en su organización? (*Marque todos*)

- ☐ Encriptación en tránsito (TLS, VPN)
- ☐ Encriptación en reposo para datos críticos
- ☐ Encriptación en reposo para todos los datos sensibles
- ☐ Gestión de claves centralizada
- ☐ Rotación automática de claves
- ☐ No existe encriptación formal

[06.3.5] Data Loss Prevention (DLP)

¿Existe un sistema o política DLP para prevenir exfiltración de datos?

- 0 = No existe
- 1 = Ad-hoc; sin automatización
- 2 = Herramienta DLP básica instalada
- 3 = DLP implementado; monitoreo activo; alertas funcionales
- 4 = DLP avanzado; machine learning; integrado con incident response

MÓDULO 7: ANÁLISIS DE VULNERABILIDADES Y VALIDACIÓN

Tiempo estimado: 8-10 minutos

Este módulo profundiza en cómo se identifican, priorizan y gestionan vulnerabilidades mediante análisis sistemático.

7.1 Análisis de Vulnerabilidades

[V7.1.1] Cobertura de Escaneo de Vulnerabilidades

¿Cuál es la cobertura de aplicaciones/sistemas que **reciben escaneo de vulnerabilidades regularmente**?

- 0-25%
- 26-50%
- 51-75%
- 76-90%
- 91-100%

[V7.1.2] Frecuencia de Escaneo

¿Con qué frecuencia se escanean aplicaciones/sistemas en búsqueda de vulnerabilidades?

- Ad-hoc / Bajo demanda solamente
- Mensual
- Trimestral
- Semanal
- Continuo / Diario

[V7.1.3] Sistemas de Escaneo Utilizados

¿Cuáles de las siguientes herramientas/metodologías se utilizan para identificar vulnerabilidades?
(*Marque todos*)

- ☐ SAST (Análisis estático: SonarQube, Checkmarx, Fortify)
- ☐ DAST (Análisis dinámico: Burp Suite, OWASP ZAP, Acunetix)
- ☐ SCA (Análisis de componentes: Snyk, Black Duck, WhiteSource)
- ☐ Escaneo de infraestructura (Nessus, Qualys, OpenVAS)
- ☐ Escáneres de contenedores (Trivy, Anchore, Harbor)
- ☐ Penetración manual (Red team interno o externo)
- ☐ Fuzzing / Testing de robustez
- ☐ Análisis de código estático manual (code review)
- ☐ Ninguno formal; solo reportes externos

[V7.1.4] Priorización con CVSS/EPSS

¿Cuáles de los siguientes sistemas de puntuación se utilizan para priorizar vulnerabilidades? (*Marque todos*)

- ☐ CVSS (Common Vulnerability Scoring System) - versión 3.x o 4.0
- ☐ EPSS (Exploit Prediction Scoring System) - probabilidad de explotación
- ☐ SSVC (Stakeholder-Specific Vulnerability Categorization)
- ☐ Asset criticality + data sensitivity custom scoring
- ☐ Manual scoring / juicio experto
- ☐ No utilizamos sistema formal de puntuación

[V7.1.5] Contextualización de Vulnerabilidades

Al priorizar vulnerabilidades, ¿se considera el **contexto** de la organización? (*Marque todos*)

- ☐ Criticidad del activo (sistema crítico vs. no crítico)
- ☐ Exposición de la red (internet-facing vs. interno)
- ☐ Sensibilidad de datos procesados
- ☐ Requisitos regulatorios que aplican
- ☐ Evidencia de explotación activa (KEV, threat intel)
- ☐ Disponibilidad de exploit / herramientas públicas
- ☐ Solo se considera severidad técnica (CVSS)

7.2 Pruebas de Penetración (Penetration Testing)

[V7.2.1] Cobertura de Penetration Testing

¿Cuál de la siguiente cobertura de penetration testing se realiza en su organización?

- 0 = Ninguno / Muy ad-hoc
- 1 = Pentesting de aplicación web (1-2 críticas)
- 2 = Pentesting de aplicación web (todas críticas) + infraestructura limitada
- 3 = Pentesting integral (aplicaciones + infraestructura + seguridad física de datacenter)
- 4 = Pentesting integral + red team interno + social engineering testing

[V7.2.2] Frecuencia de Penetration Testing

¿Con qué frecuencia se realiza pentesting externo independiente (recomendado: al menos anual)?

- Nunca
- Cada 2-3 años
- Anual
- Semestral o por mayor release
- Trimestral o más frecuente

[V7.2.3] Scope de Penetration Testing

¿Cuál es típicamente el **scope** de un penetration test en su organización?

- Aplicación web específica solamente
- Aplicación web + APIs + backends
- Aplicación web + APIs + backends + infraestructura + redes
- Penetration test integral + supply chain (third-parties)
- No realizamos pentesting formal

[V7.2.4] Metodología de Pentesting

¿Sigue su organización una metodología estándar en penetration testing?

- 0 = Ad-hoc / No hay metodología formal
- 1 = Adaptación de OWASP Testing Guide o similar
- 2 = Metodología propia documentada
- 3 = NIST SP 800-115, PTES (Penetration Testing Execution Standard), o equivalente
- 4 = Metodología estándar + framework de threat modeling (MITRE ATT&CK, etc.)

[V7.2.5] Seguimiento de Hallazgos

¿Cómo se rastrea y cierra los hallazgos de penetration testing?

- 0 = No se rastrea formalmente
- 1 = Se documenta en reporte; cierre manual ad-hoc
- 2 = Se rastrea en issue tracker; SLA informal
- 3 = Se rastrea en defect system; SLA por severidad; validación de remediación
- 4 = Integrado con CVSSM / scoring; automated remediation verification; trend analysis

MÓDULO 8: SIEM Y OPERACIONES DE SEGURIDAD

Tiempo estimado: 8-10 minutos

Este módulo evalúa la madurez de SIEM y operaciones de seguridad (SOC - Security Operations Center).

8.1 Infraestructura SIEM

[S8.1.1] Existencia de SIEM

¿Su organización implementa una solución SIEM (Security Information and Event Management)?

- ☐ No (Ir a 8.1.5)
- ☐ Sí, pero muy básica (agregación de logs sin correlación)
- ☐ Sí, SIEM estándar (ej: Splunk, ELK, Azure Sentinel, etc.)
- ☐ Sí, SIEM enterprise (con SOC dedicado)

[8.1.1 – Si respondió Sí, continúe]

[S8.1.2] Cobertura de Fuentes de Datos

¿Cuál es la cobertura de fuentes de datos que envían logs a su SIEM?

- 0-25% (Solo aplicaciones críticas)
- 26-50% (Aplicaciones + algunos sistemas)
- 51-75% (Mayoría de aplicaciones y sistemas)
- 76-90% (Casi todo: aplicaciones, sistemas, firewalls, IDSs, endpoints)
- 91-100% (Cobertura completa; incluyendo cloud)

[S8.1.3] Tipos de Eventos Monitoreados

¿Cuáles de los siguientes tipos de eventos se monitorizan en su SIEM? (*Marque todos*)

- ☐ Acceso a aplicaciones (login, logout, cambios de rol)
- ☐ Cambios de configuración (sistema, aplicación)
- ☐ Intentos de acceso fallidos / anomalías de autenticación
- ☐ Acceso a datos sensibles / descargas masivas
- ☐ Ejecución de comandos privilegiados (sudo, run as admin)
- ☐ Cambios en permisos de archivos / control de acceso
- ☐ Errores de aplicación / exceptions
- ☐ Tráfico de red (firewall, IDS, proxy logs)
- ☐ Cambios en sistemas de archivos críticos
- ☐ Ejecución de procesos sospechosos

[S8.1.4] Rendimiento SIEM

¿Cuál es el estado de rendimiento de su SIEM?

- 0 = Inestable; frecuentes tiempos muertos
- 1 = Funcional pero lento; queries toman > 5 minutos
- 2 = Aceptable; queries < 5 minutos; ocasionales cuellos de botella
- 3 = Bueno; queries < 1 minuto; infraestructura escalable
- 4 = Excelente; queries < 10 segundos; totalmente escalable; cloud-native

8.2 Detección y Correlación

[S8.2.1] Reglas de Detección

¿Cuántas reglas de detección/correlación activas tiene definidas su SIEM?

- 0-10 (Muy básico)
- 11-50 (Básico)
- 51-200 (Moderado)
- 201-500 (Avanzado)
- 500+ (Muy avanzado; incluyendo ML)

[S8.2.2] Mapeo a Patrones de Ataque

¿Se mapean las reglas de detección a patrones de ataque conocidos?

- 0 = No; reglas genéricas
- 1 = Ad-hoc; sin mapping formal
- 2 = Algunos mapeados a OWASP Top 10
- 3 = Mapeados a MITRE ATT&CK o similar; % significativo
- 4 = Completamente mapeados a ATT&CK cobertura conocida

[S8.2.3] Falsos Positivos

¿Cuál es la **proporción típica de falsos positivos** en alertas generadas?

-

80% (Saturación; mayormente ruido)

- 50-80% (Alto ruido)
- 20-50% (Moderado)
- 5-20% (Bien tuned)
- < 5% (Altamente optimizado)
- No tenemos métrica

80% (Saturación; mayormente ruido)

[S8.2.4] Indicador de Éxito en Detección

De los incidentes de seguridad que su organización **detectó activamente** (vs. reportados externamente), ¿qué porcentaje fue detectado por el SIEM/SOC?

- 0-25%
- 26-50%
- 51-75%
- 76-90%
- 91-100%
- No tenemos métrica

8.3 Operaciones SOC y Respuesta

[S8.3.1] Equipo SOC

¿Existe un equipo dedicado de SOC (Security Operations Center)?

- 0 = No; respuesta ad-hoc
- 1 = Equipo pequeño (1-2 personas); IT dual-role
- 2 = Equipo dedicado pequeño (2-5 personas)
- 3 = Equipo SOC completo (5-10+ personas; roles especializados)
- 4 = SOC enterprise con múltiples shifts; 24/7 coverage

[S8.3.2] Cobertura 24/7

¿Su SOC/Security Ops proporciona cobertura **24/7/365**?

- No; horario de negocio solamente
- Parcial (18/7 o 16/7)
- Sí, pero con escalación lenta fuera de horas
- Sí, cobertura completa con escalación rápida
- Sí, con respuesta automatizada

[S8.3.3] Playbooks de Respuesta

¿Existen playbooks documentados para responder a diferentes tipos de incidentes?

- 0 = No
- 1 = Ad-hoc; algunos playbooks informales
- 2 = Playbooks documentados pero no actualizados
- 3 = Playbooks documentados y actualizados; cobertura de incidentes comunes
- 4 = Playbooks vivos; integrados con SOAR; respuesta automatizada donde aplica

[S8.3.4] Integración con SOAR

(SOAR = *Security Orchestration, Automation and Response*)

¿Está su SIEM/SOC integrado con una plataforma SOAR?

- 0 = No
- 1 = Integración manual entre herramientas
- 2 = Alguna automatización; mediante scripts personalizados
- 3 = Plataforma SOAR implementada; cobertura de casos comunes
- 4 = SOAR completo; orquestación automatizada de la mayoría de respuestas

[S8.3.5] Automación de Respuesta

¿Cuál es el porcentaje de incidentes que se **contienen automáticamente** (sin intervención manual)?

- 0% (Todo manual)
- 1-25%
- 26-50%
- 51-75%
- 76-100%

MÓDULO 9: CAPACITACIÓN Y CONCIENCIA EN SEGURIDAD

Tiempo estimado: 8-10 minutos

Este módulo evalúa la madurez del programa de capacitación y conciencia en ciberseguridad.

9.1 Programa de Capacitación

[T9.1.1] Cobertura de Capacitación Inicial

¿Qué porcentaje de **nuevos empleados** reciben capacitación en ciberseguridad como parte de la onboarding?

- 0-25%
- 26-50%
- 51-75%
- 76-90%
- 91-100%

[T9.1.2] Capacitación Anual Requerida

¿Existe un requisito de capacitación en seguridad **anual** para empleados?

- 0 = No
- 1 = Recomendado pero no obligatorio
- 2 = Obligatorio; pero cumplimiento bajo (< 70%)
- 3 = Obligatorio; cumplimiento moderado (70-90%)
- 4 = Obligatorio; cumplimiento alto (> 90%); tracked y enforced

[T9.1.3] Capacitación por Rol

¿Se proporciona capacitación **específica por rol** (Developer, Admin, Manager, etc.)?

- 0 = No; capacitación genérica para todos
- 1 = Alguna diferenciación; no consistente
- 2 = Diferenciación clara; contenido específico por rol
- 3 = Contenido específico + nivel de profundidad por rol
- 4 = Personalización completa; adaptado a responsabilidades individuales

[T9.1.4] Formatos de Capacitación

¿Cuáles de los siguientes formatos de capacitación se utilizan? (*Marque todos*)

- ☐ E-learning online (cursos asincronos)
- ☐ Videos didácticos / tutoriales
- ☐ Sesiones en vivo (webinars, workshops)
- ☐ Entrenamiento presencial / en persona
- ☐ Simulaciones de ataque (phishing, social engineering)
- ☐ Hands-on labs / laboratorios prácticos
- ☐ Gamification (quizzes, competencias, badges)
- ☐ Newsletters / comunicaciones de seguridad regulares
- ☐ Artículos / documentos de referencia
- ☐ Peer learning / mentoría

[T9.1.5] Inversión en Capacitación

¿Cuánto presupuesto se asigna **anualmente** a capacitación en ciberseguridad por empleado?

- \$0-25 / empleado / año (Muy bajo)
- \$25-100
- \$100-250
- \$250-500
- \$500+ / empleado / año (Muy alto)
- No tengo información

9.2 Conciencia en Seguridad (Security Awareness)

[T9.2.1] Simulación de Phishing

¿Se conducen simulaciones de phishing para medir y mejorar conciencia?

- 0 = No
- 1 = Ad-hoc; muy ocasional (1 vez cada 2 años)
- 2 = Anual
- 3 = Trimestral
- 4 = Mensual o continuo

[T9.2.2] Tasa de Fallo en Simulación

¿Cuál es la **tasa de fallo** típica en simulaciones de phishing (% de empleados que clicquean)?

-

50% (Muy alto riesgo)

- 30-50% (Alto riesgo)
- 10-30% (Riesgo moderado)
- < 10% (Bajo riesgo)
- < 5% (Excelente)
- No realizamos simulaciones

50% (Muy alto riesgo)

[T9.2.3] Respuesta a Phishing Fallido

¿Qué ocurre cuando un empleado falla una simulación de phishing?

- 0 = Nada; sin seguimiento
- 1 = Se registra; retroalimentación ocasional
- 2 = Retroalimentación automática; training remedial recomendado
- 3 = Training remedial obligatorio; progresión automática
- 4 = Training personalizado + seguimiento; análisis de patrón por equipo

[T9.2.4] Reporte de Phishing

¿Qué porcentaje de empleados **reporta activamente** emails sospechosos?

- 0-10%
- 11-25%
- 26-50%
- 51-75%
- 76-100%
- No tenemos métrica

[T9.2.5] Tiempo de Reporte

¿Cuál es el **tiempo promedio** desde que un empleado recibe un email sospechoso hasta que lo **reporta a seguridad**?

-

1 hora (Lento / raramente reporta)

- 30 minutos - 1 hora
- 10-30 minutos
- < 10 minutos (Muy rápido)
- No tenemos métrica

1 hora (Lento / raramente reporta)

9.3 Cultura de Seguridad

[T9.3.1] Percepción de Seguridad

¿Cómo describe los empleados su percepción general de seguridad?

- 0 = "Seguridad ralentiza mi trabajo" / Barrera
- 1 = Neutral / "Es necesario pero molesto"
- 2 = Positiva / "Importante para la empresa"
- 3 = Muy positiva / "Responsabilidad compartida"
- 4 = Excelente / "Seguridad es parte de mi rol" (Integrado)

[T9.3.2] Reporte de Vulnerabilidades

¿Sienten los empleados que pueden reportar vulnerabilidades / problemas de seguridad **sin miedo a represalias**?

- 0 = No; raramente reportan
- 1 = Algunos reportan; con hesitación
- 2 = Mayoría reporta; existe confianza parcial
- 3 = Mayoritariamente reportan; alto nivel de confianza
- 4 = Todos reportan activamente; cultura establecida

[T9.3.3] Incentivos de Seguridad

¿Existen incentivos o reconocimiento para comportamientos seguros o reportes de seguridad?

- 0 = No
- 1 = Ad-hoc; reconocimiento ocasional
- 2 = Programa informal; incentivos inconsistentes
- 3 = Programa formal; incentivos claros por categoría
- 4 = Programa gamificado; integrado en evaluación de desempeño

[T9.3.4] Bug Bounty / Programa de Divulgación

¿Tiene su organización un programa de bug bounty o divulgación responsable?

- 0 = No
- 1 = En desarrollo / piloto
- 2 = Programa básico (interno solamente)
- 3 = Programa para externos; en plataforma pública
- 4 = Programa maduro; con presupuesto significativo

MÓDULO 10: CUMPLIMIENTO NORMATIVO Y REGULATORIO

Tiempo estimado: 5-7 minutos

Este módulo evalúa alineación con marcos regulatorios que aplican a su organización.

10.1 Marcos Regulatorios

[C10.1.1] Marcos Aplicables

¿Cuáles de los siguientes marcos regulatorios aplican a su organización? (*Marque todos*)

- ☐ GDPR (General Data Protection Regulation) - UE
- ☐ NIS2 (Network and Information Security Directive 2) - UE (en transposición)
- ☐ CRA (Cyber Resilience Act) - UE (en vigor 10-dic-2024)
- ☐ DORA (Digital Operational Resilience Act) - UE (Sector financiero)
- ☐ PCI-DSS (Payment Card Industry Data Security Standard)
- ☐ HIPAA / Regulación de Sanidad (si aplica)
- ☐ LSSI-CE (Ley de Servicios de la Sociedad de la Información) - España
- ☐ ENS (Estándares de Seguridad de la Administración Electrónica) - España
- ☐ ISO 27001 / ISO 27002
- ☐ SOC 2 Type II / SOC 3
- ☐ CMMC 2.0 (si contrata a DoD)
- ☐ Otro: ____
- Ninguno / No seguro

[C10.1.2] Madurez vs. Requisitos Mínimos

Para cada marco que aplica, ¿cómo se posiciona su madurez actual respecto al requisito mínimo?

[Preguntar para los 3-4 marcos principales que el respondiente indicó]

Framework: ____

- Muy por debajo del mínimo (Brechas críticas)
- Por debajo del mínimo (Brechas significativas)
- En el mínimo (Apenas cumple)
- Por encima del mínimo (Con algún margen)
- Significativamente por encima (Bem posicionado)

[C10.1.3] Auditoría de Cumplimiento

¿Con qué frecuencia se audita el cumplimiento contra marcos regulatorios?

- 0 = Nunca
- 1 = Ad-hoc (cuando se identifica problema)
- 2 = Anual
- 3 = Semestral o por audit externo
- 4 = Continuo / Trimestral

[C10.1.4] Responsabilidad Regulatoria

¿Quién es **explícitamente responsable** del cumplimiento regulatorio?

- 0 = No hay responsable claro
- 1 = Compartida / Múltiples stakeholders sin propiedad
- 2 = Asignada a Compliance/Legal; sin propiedad técnica clara
- 3 = Propiedad clara (CISO o Compliance Officer)
- 4 = Propiedad integrada (CISO + Compliance + Legal + Negocio)

MÓDULO 11: CALIDAD Y CONFIANZA EN RESPUESTAS

Tiempo estimado: 2-3 minutos

Esta sección final captura meta-información sobre la confiabilidad de las respuestas.

11.1 Confianza y Facilidad

[Q11.1.1] Confianza General en Respuestas

¿Cuál es su nivel de **confianza** en las respuestas que acaba de dar?

- 0 = Muy baja (Muchas áreas donde no tenía visibilidad)
- 1 = Baja (Incertidumbre en varias preguntas)
- 2 = Moderada (Algunos temas menos seguros)
- 3 = Alta (Conocimiento razonable; pocas áreas dudosas)
- 4 = Muy alta (Confianza en casi todas las respuestas)

[Q11.1.2] Facilidad de la Encuesta

¿Cuál fue la dificultad general de la encuesta?

- 1 = Muy fácil (Preguntas claras; respuestas obvias)
- 2 = Fácil
- 3 = Moderada (Algunas preguntas requerían reflexión)
- 4 = Difícil (Preguntas ambiguas; dificultad para posicionarse)
- 5 = Muy difícil (Confuso; sin visibilidad suficiente)

[Q11.1.3] Brecha de Comunicación Identificada

¿Identificó áreas donde **diferentes roles en su organización** probablemente tendrían respuestas **significativamente diferentes**?

- ☐ Governance (Strategy, Policy, Education)
- ☐ Design (Threat Assessment, Architecture)
- ☐ Implementation (Build, Deployment, Dependencies)
- ☐ Verification (Testing, Penetration Testing)
- ☐ Operations (Incident Management, Infrastructure, Data Protection)
- ☐ SIEM / Operaciones de Seguridad
- ☐ Capacitación / Conciencia
- Ninguno; probablemente coincidirían
- No tengo suficiente visibilidad

11.2 Observaciones Adicionales

[Q11.2.1] Comentarios / Observaciones

¿Tiene algún comentario adicional, contexto o observación que deba considerarse en la evaluación de madurez?

[Campo de texto libre]

FIN DE LA ENCUESTA

Tiempo total completado: __ minutos

Fecha de envío: __

Gracias por su tiempo y participación rigurosa en esta evaluación.

NOTAS SOBRE LA ESCALA Y PUNTUACIÓN

Interpretación de Niveles

- Nivel 0-1: Ad-hoc, reactivo. Actividad existe pero es informal, inconsistente e impulsada por crisis.
- Nivel 2: Definido. Proceso documentado, aplicado consistentemente, pero sin métricas de eficacia.
- Nivel 3: Medido. Proceso incluye métricas; resultados monitoreados y revisados regularmente.
- Nivel 4: Optimizado. Proceso automatizado; mejora continua sistemática basada en datos.

Conversión a Puntuación SAMM

La encuesta utiliza una escala 0-4 que **alinha directamente** con SAMM v2:

- Respuestas 0-1 mapean a SAMM L0-L1
- Respuesta 2 mapea a SAMM L2
- Respuesta 3 mapea a SAMM L3
- Respuesta 4 mapea a SAMM L3-L3+ (optimizado)

Cálculo de Puntuación por Práctica:

Puntuación Práctica = $(\sum \text{respuestas en práctica}) / (\# \text{ preguntas en práctica})$

Cálculo de Puntuación por Función:

$$\text{Puntuación Función} = (\Sigma \text{ prácticas en función}) / (\# \text{ prácticas en función})$$

Puntuación Global SAMM:

$$\text{Puntuación Global} = (\Sigma \text{ funciones}) / 5 \text{ funciones}$$

El resultado es una **puntuación 0-4 que es comparable con benchmarks SAMM globales.**

APÉNDICE: MAPEO A FRAMEWORKS INTERNACIONALES

Esta encuesta se alinea con:

- **OWASP SAMM v2** (Framework primario)
- **NIST Cybersecurity Framework 2.0** (Govern, Protect, Detect, Respond, Recover)
- **ISO/IEC 27001:2022** (A.14: Secure development)
- **CIS Controls v8** (Controls 3-7: Secure Development)
- **NIS2 Directive Requirements** (EU 2022/2555)
- **Cyber Resilience Act (CRA)** (EU 2024/2847)
- **SAFECode Best Practices**
- **Security Awareness Program Maturity Models** (KnowBe4 PMA)